

clubFutbolin: Arquitectura Backend y Seguridad

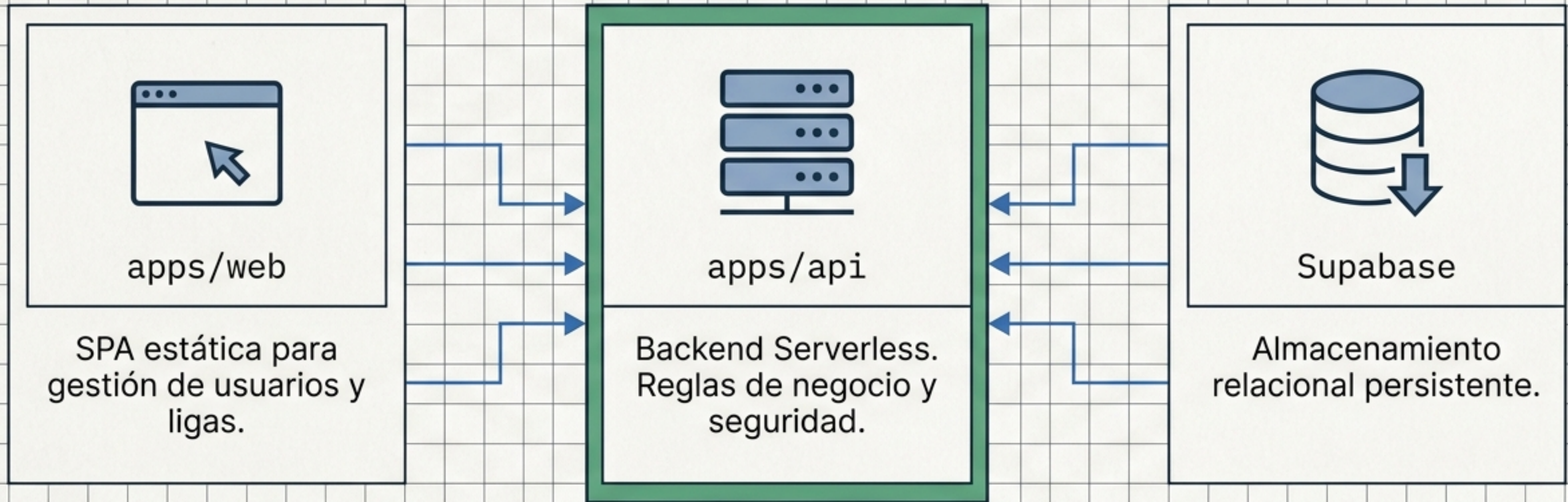
Construyendo un núcleo escalable, tipado e inexpugnable.

[MONOREPO]

[API_REST]

[ZERO_TRUST]

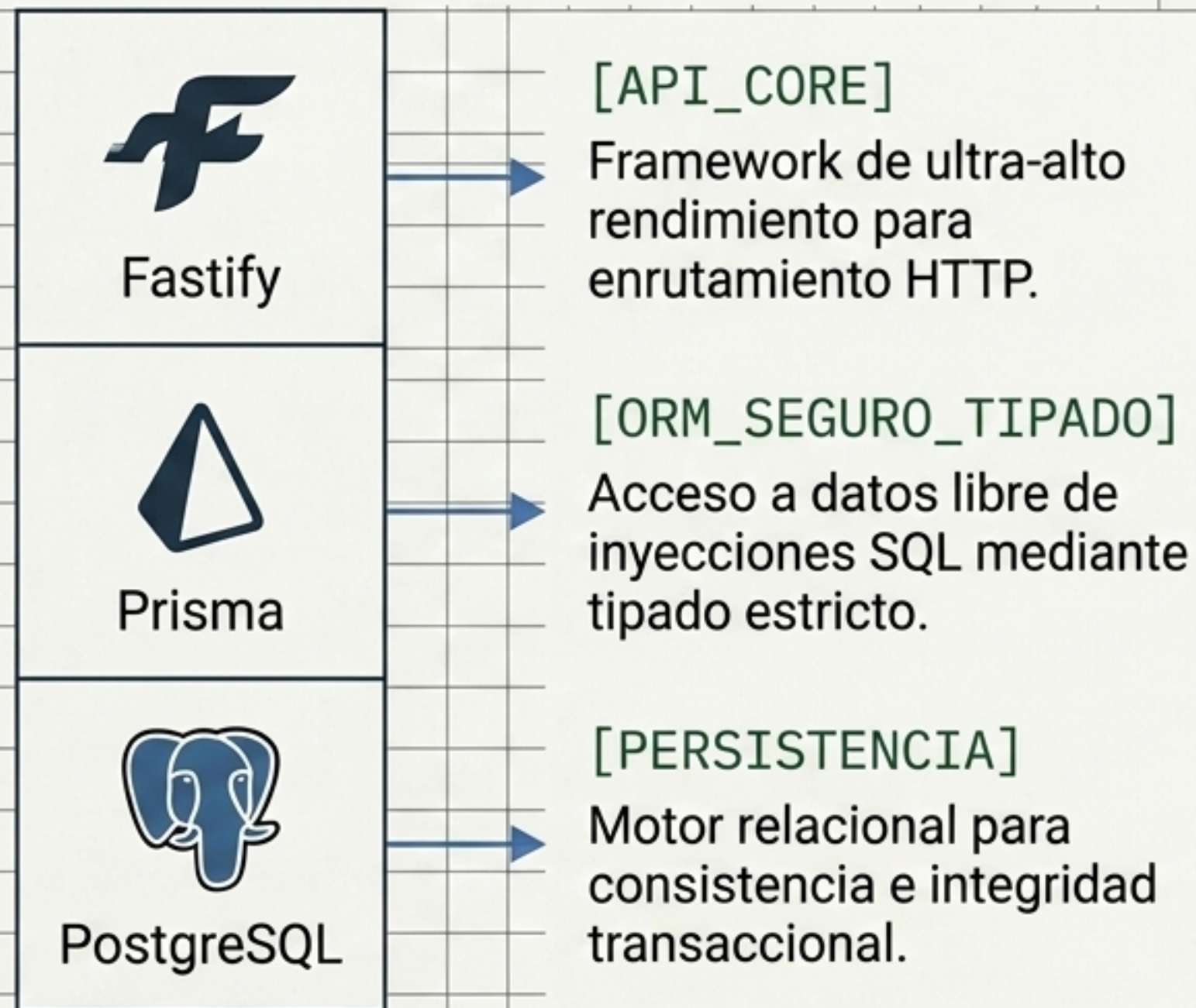
Topología del Monorepo



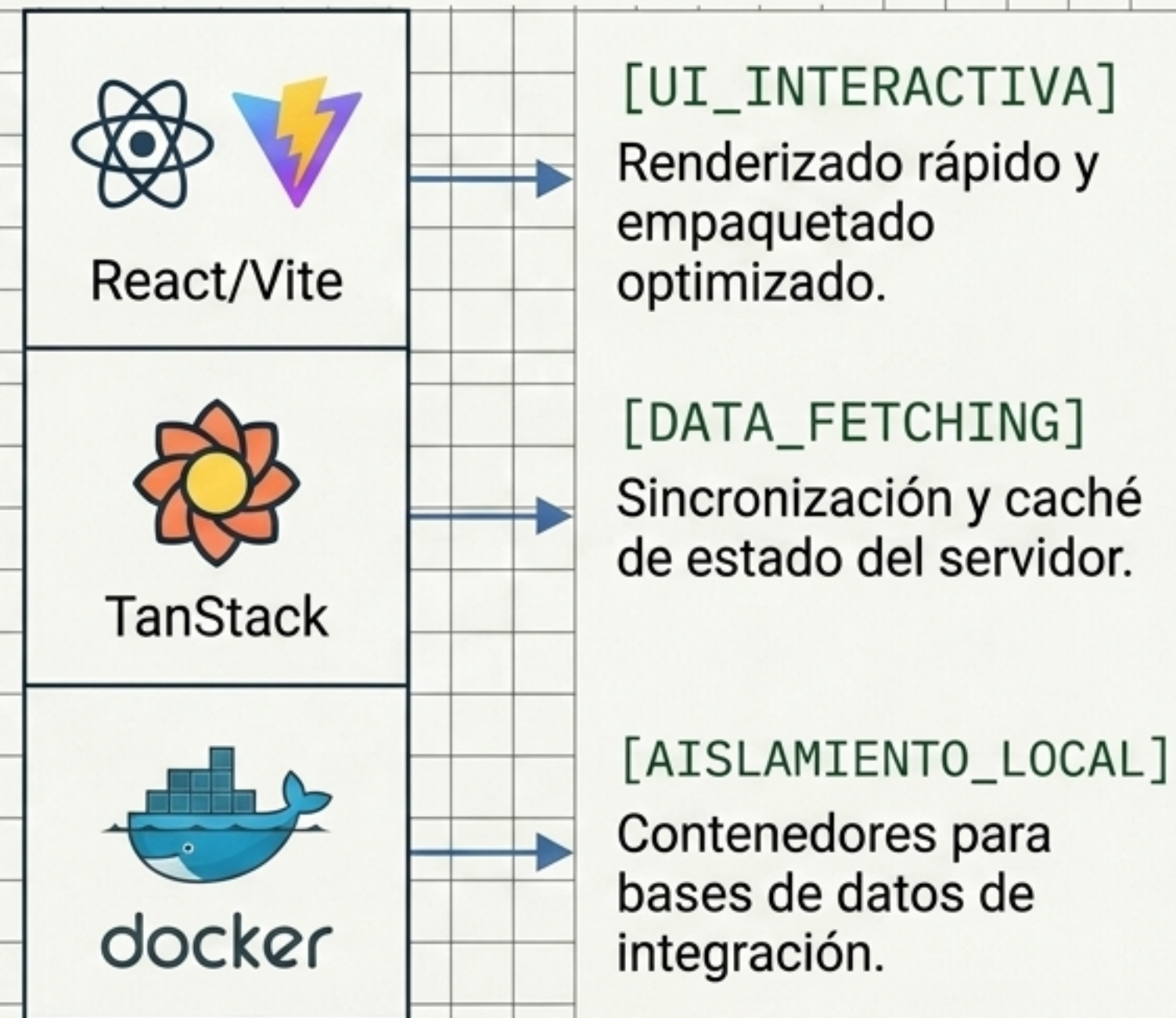
Monorepo fullstack diseñado para la gestión integral de un club de fútbol, operando bajo contratos HTTP estrictos y separación clara de responsabilidades.

Ecosistema Tecnológico

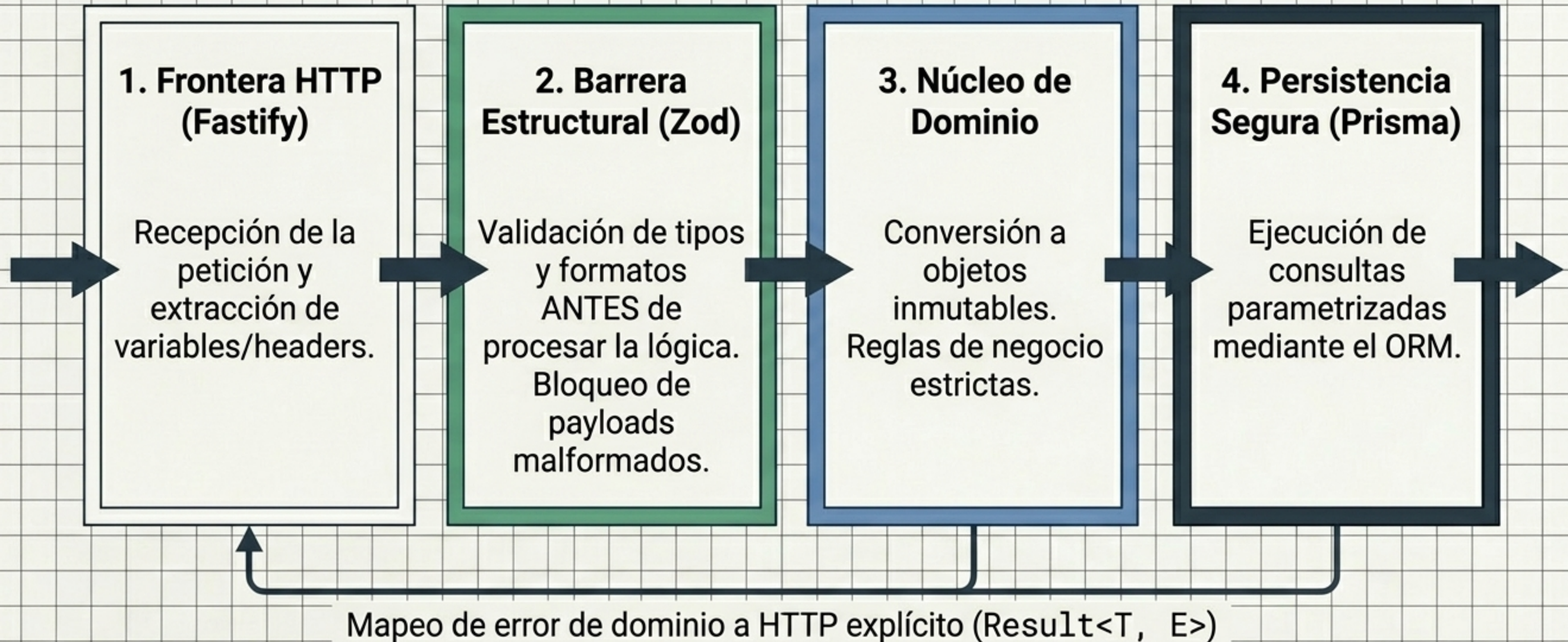
Backend & Datos - Foco Principal



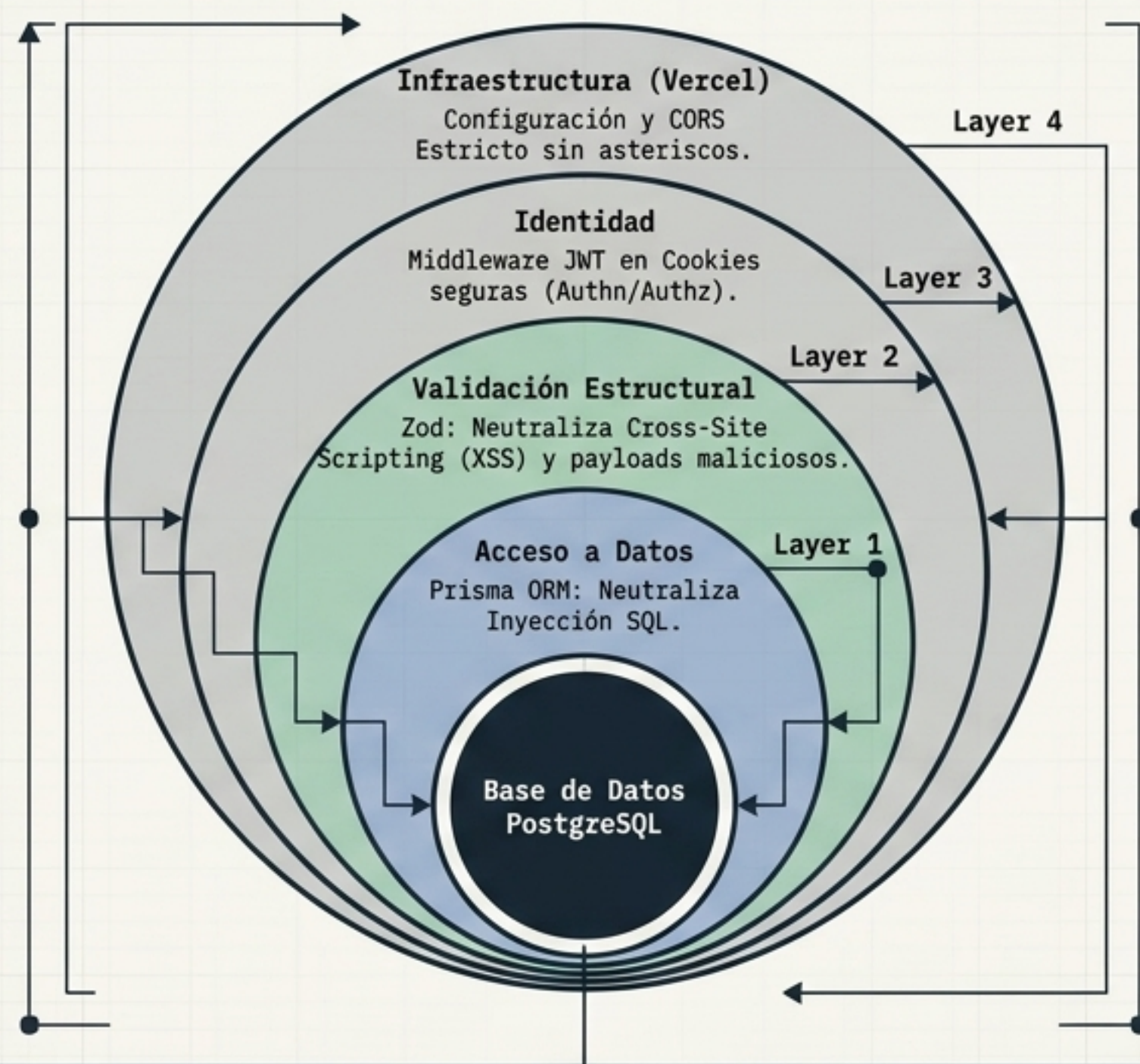
Frontend & Ecosistema



Arquitectura de API HTTP: El Ciclo de la Petición



Postura de Seguridad: Defensa en Profundidad



Una petición maliciosa debe atravesar cuatro barreras de seguridad independientes antes de interactuar con el estado del sistema.

Seguridad I: Frontera y Transporte

Panel Izquierdo - Configuración

```
AUTH_COOKIE_SECURE=true  
AUTH_COOKIE_SAME_SITE=lax  
TRUST_PROXY=true  
JWT_EXPIRES_IN=7d
```

Panel Derecho - Impacto Arquitectónico

Tokens Ocultos

El JWT se almacena exclusivamente en cookies HttpOnly, previniendo robo mediante JavaScript (mitigación XSS).

Tránsito Seguro

La API aborta operaciones si AUTH_COOKIE_SECURE es false en producción.

Mitigación CSRF

Política SameSite aplicada estrictamente en la frontera HTTP.

Seguridad II: Inyección y Tipado Estricto

Vector de Ataque Potencial	Solución Implementada
Inyección SQL.	 Prisma ORM parameterization. Todas las consultas son generadas por el ORM, eliminando la concatenación manual de strings.
Anomalías de Datos y Tipos.	 Tipado estricto de TypeScript (Regla: sin any). Tipos garantizados desde la base de datos hasta el handler.
Payload Malformado.	 Validación de entrada en frontera con Zod . El <i>body</i> nunca llega al caso de uso si incumple la estructura.

Contrato de API y Control de Acceso (RBAC)

Recursos	Público	USER	ADMIN
Healthcheck & Login	✓ Acceso total	-	-
Players	✓ GET list / POST	✓ GET/PATCH propio	✓ Control total
Leagues / Teams / Seasons	✓ GET Lectura abierta	-	✓ POST/PATCH/DELETE
Rosters (Plantillas)	-	-	✓ Exclusivo para inscripciones

El esquema asegura que la lectura del club es transparente, pero la administración del ecosistema requiere JWT con privilegios explícitos **createRequireAdmin**.

Estrategia de Calidad y Pruebas

E2E

Playwright (CI). Cobertura de flujos críticos de usuario contra la SPA y API real.

Integración HTTP

Vitest interactuando con PostgreSQL aislado en contenedor Docker (puerto 5433). Limpieza automática entre tests.

Pruebas Unitarias

Validaciones de dominio rápidas. Sin dependencia de BD.

Calidad Operativa

Puertas mínimas pre-merge:

- Linting
- Typecheck (sin errores)
- Tests Unitarios y de Integración en verde.

Despliegue y Topología de Producción



Monitoreo continuo de SCA/SAST y rotación de JWT_SECRET por política interna.

Developer Experience: Arranque del Monorepo

Paso 1: Infraestructura Base

```
docker-compose up -d
```



Levanta la instancia local de PostgreSQL y su volumen persistente.

Paso 2: Esquema y Datos

```
npx prisma db push &&  
prisma db seed
```



Sincroniza esquemas y genera perfiles de prueba automáticos (Admin y User).

Paso 3: Servidores Locales

```
npm run dev
```



Terminal 1: Fastify API (puerto 3000 con Swagger).
Terminal 2: Vite SPA (puerto 5173).

Síntesis Arquitectónica

clubFutbolin

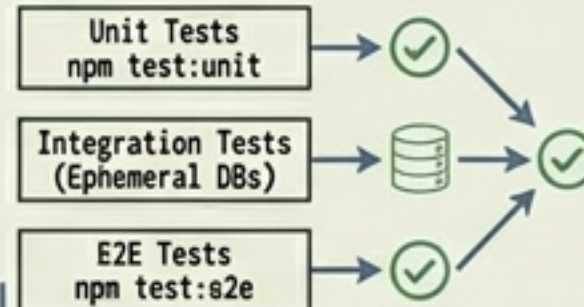
Pilar 1: Seguridad Inherente

Tipado estricto integral
(Prisma + TypeScript + Zod)
erradica inyecciones y
anomalías desde la
compilación.



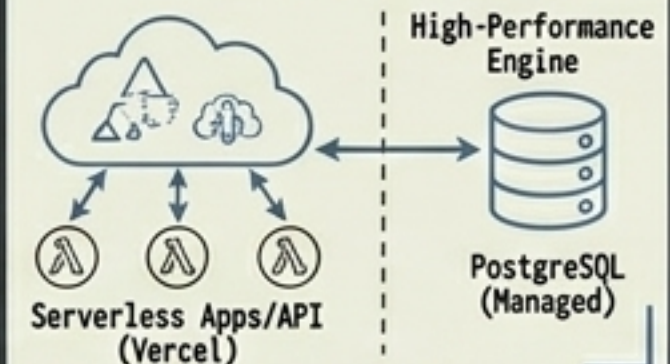
Pilar 2: Fiabilidad Demostrable

Estrategia de testing de
múltiples capas, con
bases de datos efímeras
dedicadas para integración.



Pilar 3: Escalabilidad Serverless

Despliegue distribuido
desacoplado del motor
relacional de alto
rendimiento.



Una arquitectura donde la seguridad no es una capa añadida al final,
sino el cimiento fundacional del código.